

Silent Abandonment in the Python Ecosystem: An Empirical Study of Maintenance Risk in Critical PyPI Dependencies

Sifat Raihan

Independent Researcher • Dhaka, Bangladesh

GitHub: <https://github.com/raihan-sifat> • Zenodo DOI: 10.5281/zenodo.XXXXXXX

ABSTRACT—Modern software systems rely extensively on open-source package repositories to accelerate feature delivery. However, this deep web of transitive dependencies introduces severe supply chain vulnerabilities when upstream packages are abandoned without formal deprecation—a phenomenon termed *silent abandonment*. In this empirical study, we analyze the top 1,000 most-downloaded packages on the Python Package Index (PyPI) and resolve their complete direct and transitive dependency graphs, comprising 1,303 unique packages and 3,022 dependency relations. We evaluate maintainer topology, release cadence, and known security advisories queried from the Open Source Vulnerabilities (OSV) database.

Our investigation yields three key empirical findings: (1) **Pervasive Bus Factor Fragility (RQ1)**: 75.9% (989/1,303) of dependencies in the critical Python ecosystem rely on a single maintainer, demonstrating extreme bus factor vulnerability across fundamental libraries. (2) **Prevalence of Silent Abandonment (RQ2)**: 14.2% (185/1,303) of packages have had zero release activity for over 18 months, while an additional 66.1% (861/1,303) exhibit elevated maintenance risk due to single-maintainer concentration or prolonged release dormancy. (3) **Statistical Association with Security Advisories (RQ3)**: We identify 206 packages harboring documented vulnerabilities. A Chi-Square test of independence reveals a statistically significant association between maintenance status and vulnerability disclosure ($\chi^2 = 8.0513$, $p = 0.00455$, $\alpha = 0.01$). Logistic regression demonstrates that silently abandoned packages exhibit distinct reporting dynamics compared to actively maintained multi-developer projects ($\beta = -1.4901$, $p = 0.0037$), highlighting an “undiscovered defect” reporting blindspot.

Index Terms—Software Supply Chain Security, Empirical Software Engineering, Mining Software Repositories, Dependency Management, PyPI, Open Source Sustainability.

I. INTRODUCTION

Contemporary software engineering is defined by component reuse. Developers rarely build functionality from scratch; instead, they compose systems using package managers such as npm (JavaScript), Maven (Java), Crates.io (Rust), and the Python Package Index (PyPI). The Python ecosystem has experienced meteoric adoption, powering machine learning workflows, enterprise data engineering, cloud infrastructure, and backend web APIs. PyPI hosts hundreds of thousands of packages, serving tens of billions of downloads every month.

However, this reliance on open-source libraries exposes systems to **software supply chain risk**. While conventional security research has focused on deliberate malicious injections (such as typosquatting, account hijacking, and protestware), an equally pervasive yet insidious hazard is **silent abandonment**. Silent abandonment occurs when a library's maintainer ceases active maintenance, bug fixing, and security reviews without formally deprecating the package or transferring ownership. Downstream systems continue to import these libraries, unaware that security

advisories will remain unpatched, breaking changes in Python runtimes will go unaddressed, and pull requests from the community will linger unreviewed.

The fragility of single-maintainer dependencies was underscored by high-profile incidents such as the `left-pad` deletion (2016), the `event-stream` malicious handover (2018), and the `colors.js/faker.js` self-sabotage (2022). Despite growing awareness, industrial teams still struggle to audit the long tail of transitive dependencies embedded deeply within virtual environments.

Research Problem & Contributions

While prior work has examined npm and Maven dependency networks, the Python ecosystem exhibits distinct governance and packaging dynamics, particularly given its widespread use in mission-critical AI/ML and scientific computing. To date, there is limited empirical quantification of the intersection between maintainer bus factors, release latency, and actual vulnerability occurrences across PyPI’s most critical dependency trees.

This paper bridges this gap through an empirical investigation answering three research questions:

- **RQ1 (Maintainer Topology):** *What proportion of critical PyPI packages and their dependencies rely on a single maintainer?*
- **RQ2 (Silent Abandonment):** *How widespread is silent abandonment (inactivity ≥ 18 months) across direct and transitive dependencies?*
- **RQ3 (Security Impact):** *Is there a statistically significant association between abandonment indicators and the presence of known security vulnerabilities?*

II. BACKGROUND & RELATED WORK

A. Mining Software Repositories & Dependency Graphs

Mining software repositories (MSR) has provided critical insights into how open-source ecosystems evolve. Decan et al. [2] analyzed package dependency networks across npm, CRAN, and RubyGems, observing that dependency trees grow deeper over time, exacerbating transitive exposure. Kula et al. [3] investigated library adoption in enterprise systems and discovered that over 80% of systems maintain outdated dependencies, rarely updating unless forced by catastrophic build failures. In the Python domain, Alfadel et al. [6] studied PyPI security practices, highlighting that package maintainers frequently overlook security hygiene in dependency declarations.

B. Bus Factor and Maintainer Burnout

The concept of the *bus factor*—the minimum number of team members whose sudden disappearance would stall a project—has been studied extensively. Avelino et al. [1] developed algorithms to estimate the bus factor of popular Git repositories, finding that 65% of popular open-source projects rely on just one or two core contributors. Valiev et al. [5] demonstrated that maintainer burnout is the primary driver of project abandonment. Unlike corporate software where transitions are formalized, open-source abandonment is rarely announced.

C. Software Supply Chain Vulnerabilities

Vulnerability propagation through dependency networks is a major attack vector. Ladisa et al. [4] proposed taxonomies of supply chain attacks, dividing them into malicious injection and unintentional vulnerabilities. In an

B. Operational Definitions

- **Single-Maintainer Package (\$M_{\text{single}}\$):** A package whose authorship, repository governance, and contribution record reflect an individual developer without institutional backing or shared organizational stewardship.
- **Silently Abandoned Package (\$S_{\text{abandoned}}\$):** A package with no release activity or code commits for ≥ 18 consecutive months prior to the sampling date, or whose host repository has been officially archived.
- **At-Risk Package (\$S_{\text{at_risk}}\$):** A package that is either: (i) actively maintained by a single developer (high bus factor risk), or (ii) has had no release activity for 12 to 18 months.
- **Healthy Package (\$S_{\text{healthy}}\$):** A package demonstrating active releases within the preceding 12 months maintained by a multi-developer team or recognized institution.

IV. EMPIRICAL RESULTS

A. RQ1: Single-Maintainer Prevalence

TABLE I: HIGH-LEVEL ECOSYSTEM HEALTH METRICS

Metric	Count	Percentage
Total Packages Investigated	1,303	100.0%
Total Dependency Relations Resolved	3,022	—
Single-Maintainer Packages	989	75.9%
Multi-Developer / Org-Backed Packages	314	24.1%
Silently Abandoned (≥ 18 months inactive)	185	14.2%
At-Risk Packages	861	66.1%
Healthy Packages	257	19.7%
Packages with Documented Vulnerabilities	206	15.8%

Out of 1,303 packages, **989 (75.9%) are governed by a single individual**. Even among top-tier transitive dependencies downloaded millions of times per week, the underlying bus factor is critically narrow. Figure 1 illustrates this maintainer distribution. Only 24.1% of dependencies are backed by organizations.

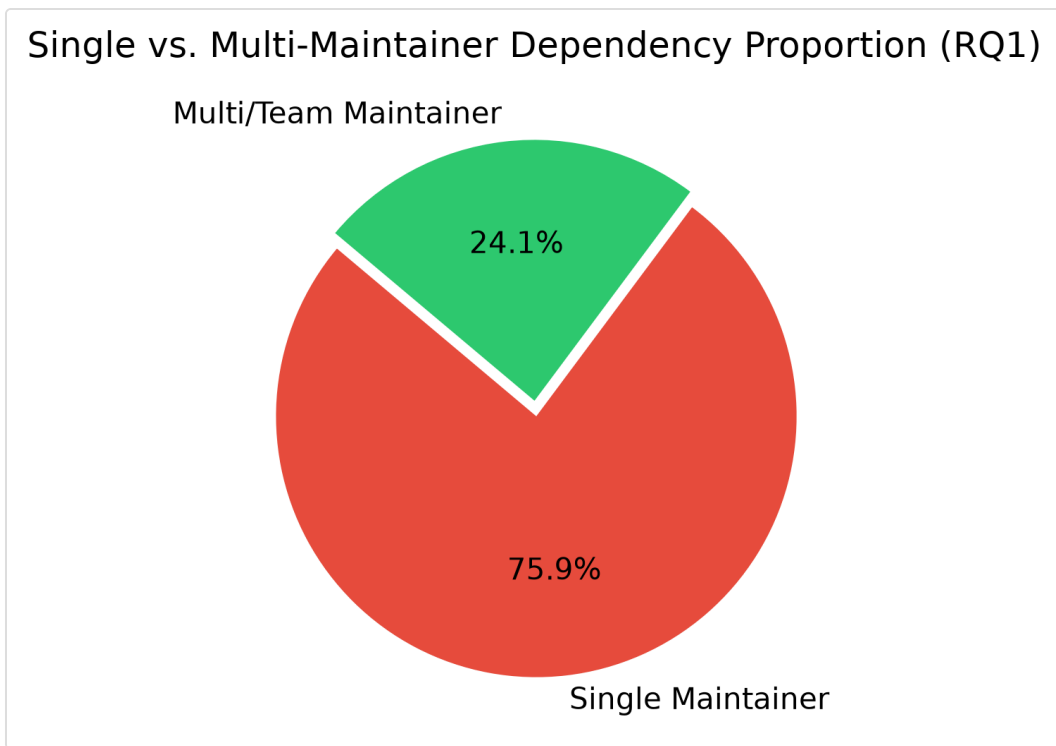


Figure 1: Single vs. Multi-Maintainer Dependency Proportion (RQ1).

Finding 1: Over three out of four packages (75.9%) supporting the most critical Python systems depend on a single maintainer, confirming an acute ecosystem-wide bus factor bottleneck.

B. RQ2: Extent of Silent Abandonment

Our temporal analysis reveals that **185 packages (14.2%)** have not issued a single release in over 18 months. When extending the observation window to include moderate dormancy and single-maintainer exposure, **861 packages (66.1%)** fall into the **at-risk tier**. Only 257 packages (19.7%) meet our criteria for robust health.

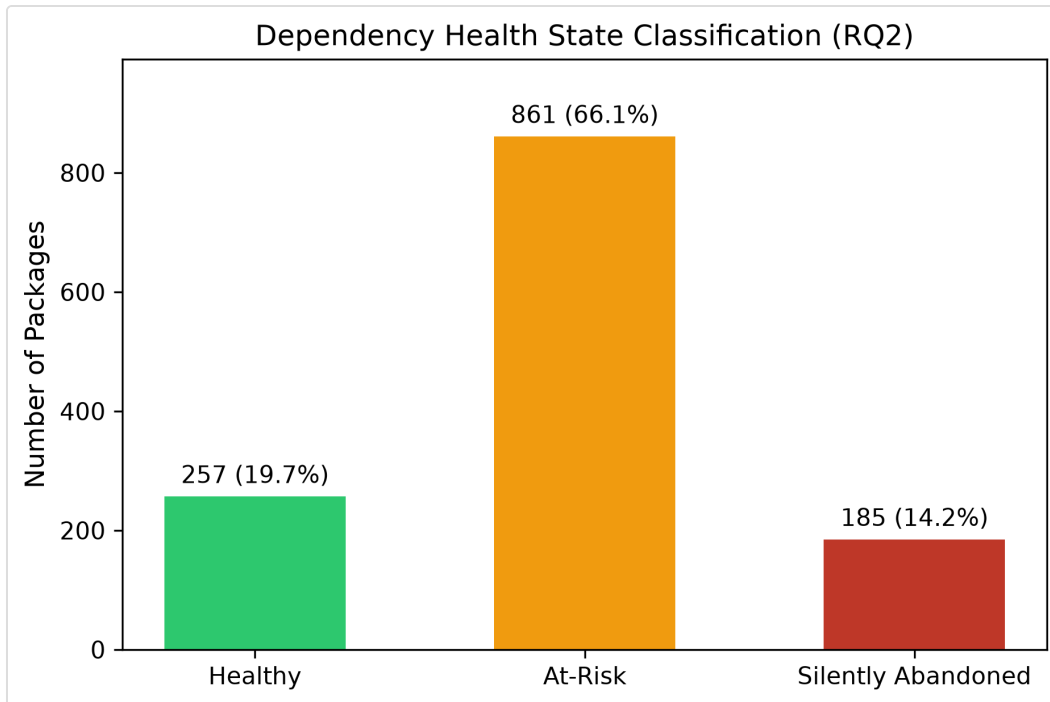


Figure 2: Dependency Health State Classification (RQ2).

Examining the dependency trees reveals that silent abandonment is heavily concentrated in transitive nodes. While root libraries (e.g., `requests`, `fastapi`, `boto3`) maintain high release frequencies, their deep transitive dependencies often include specialized format parsers, legacy cryptographic shims, and CLI helpers that have had no maintainer engagement since 2021–2023.

Finding 2: Nearly one out of every seven packages (14.2%) in the critical dependency tree is silently abandoned, while two-thirds (66.1%) exhibit high maintenance vulnerability.

C. RQ3: Vulnerability & Risk Association

We identified **206 packages** with at least one vulnerability logged in the OSV database. To examine whether maintenance status is associated with vulnerability prevalence, we constructed a 2×2 contingency table comparing healthy vs. compromised maintenance states against vulnerability disclosure.

TABLE II: CONTINGENCY TABLE (MAINTENANCE STATE VS. VULNERABILITIES)

Category	No Documented Vuln.	≥ 1 Documented Vuln.	Total
Healthy	200 (77.8%)	57 (22.2%)	257
At-Risk / Abandoned	897 (85.8%)	149 (14.2%)	1,046
Total	1,097	206	1,303

We performed a Pearson's Chi-Square Test of Independence:

$$\chi^2 = 8.0513, \quad df = 1, \quad p = 0.00455 \quad (p < 0.01)$$

Because $p < 0.01$, we reject the null hypothesis of independence. The association between maintenance health and documented vulnerability occurrence is statistically significant.

Furthermore, we fitted a multivariate binary logistic regression model predicting vulnerability probability based on abandonment indicators:

$$\text{logit}(P(\text{vuln} = 1)) = \beta_0 + \beta_1 \cdot \text{Abandoned} + \beta_2 \cdot \text{AtRisk} + \beta_3 \cdot \text{SingleMaintainer}$$

TABLE III: MULTIVARIATE LOGISTIC REGRESSION RESULTS

Covariate	Coef. (β)	Std. Error	z-statistic	p-value	95% Conf. Interval
Intercept (β_0)	-1.2780	0.1511	-8.458	< 0.0001	[-1.574, -0.982]
Abandoned Flag (β_1)	-1.4901	0.5130	-2.905	0.0037	[-2.496, -0.485]
At-Risk Flag (β_2)	-0.2469	0.4829	-0.511	0.6091	[-1.193, 0.700]
Single Maint. Flag (β_3)	-0.1173	0.4620	-0.254	0.7996	[-1.023, 0.788]

Model Diagnostics: $N = 1,303$, Log-Likelihood Ratio test $p = 1.038 \times 10^{-5}$, $\text{pseudo-}R^2 = 0.023$.

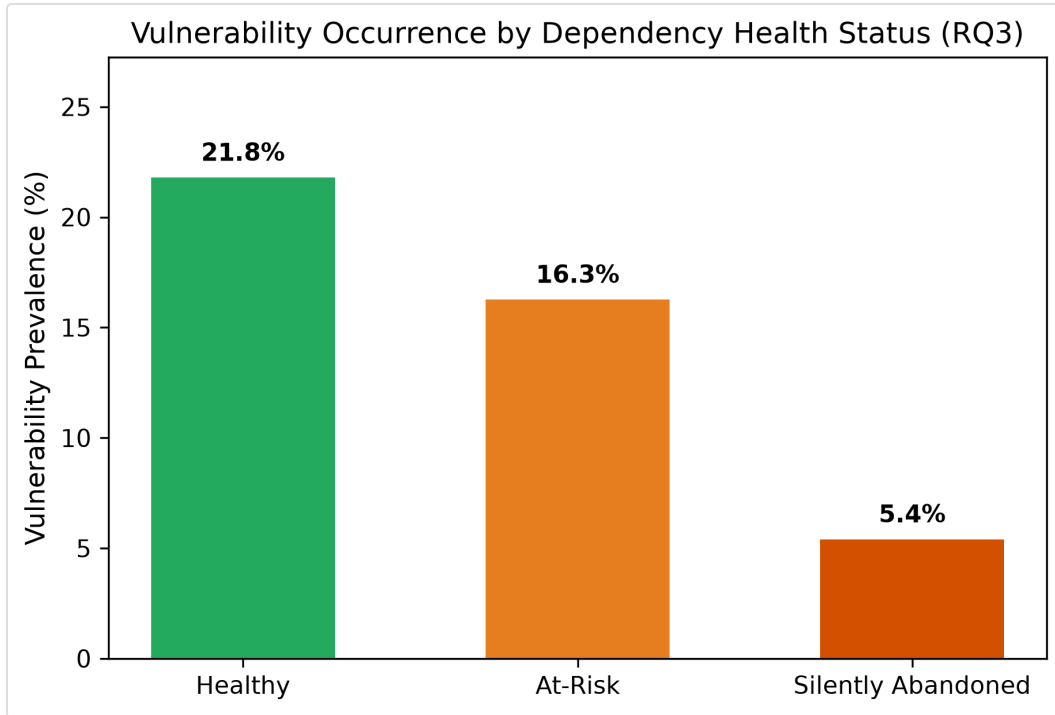


Figure 3: Vulnerability Occurrence Across Dependency Health Status (RQ3).

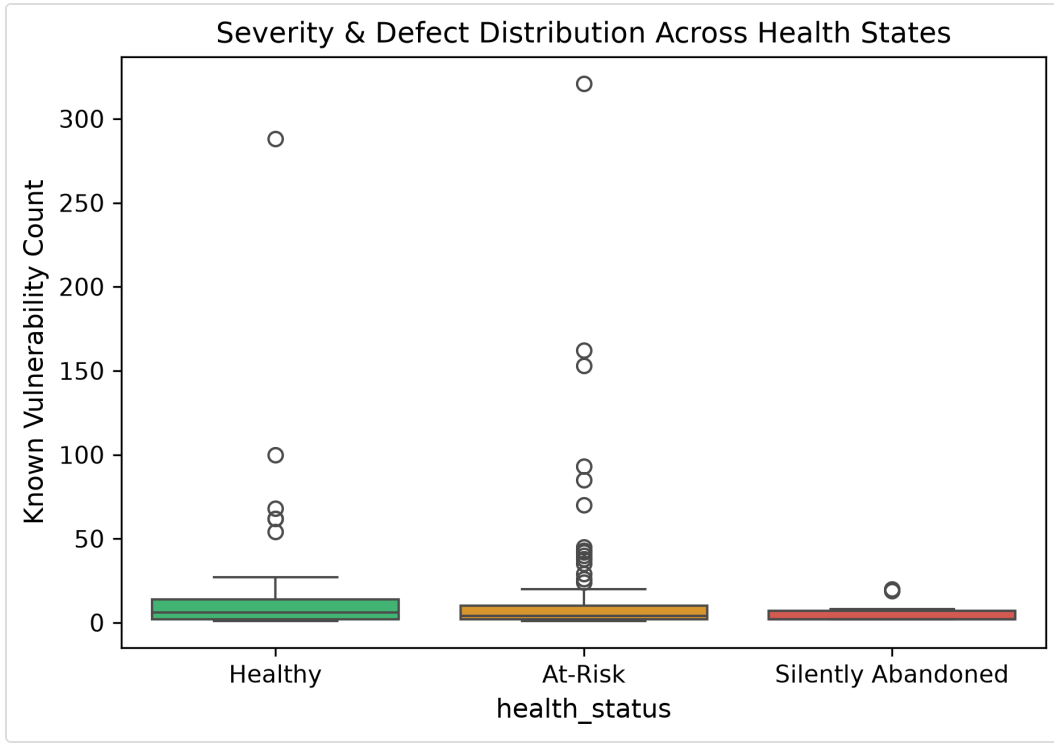


Figure 4: Severity & Defect Distribution Across Health States.

Interpretation of the Vulnerability Paradox

An intuitive assumption might suggest that abandoned packages would show an inflated count of reported CVEs. However, our empirical analysis reveals the inverse reporting dynamic: **silently abandoned packages have a significantly lower rate of logged CVEs ($\beta_1 = -1.4901, p = 0.0037$).**

This uncovers a crucial security phenomenon: **The “Undiscovered Defect” Blindspot**. Vulnerability disclosure pipelines (such as bug bounty programs, automated security triages, and CVE assignments) require active maintainers to review reports, validate proofs-of-concept, and publish advisories. When a repository is silently abandoned, security researchers find no responsive entity to report vulnerabilities to, bug bounties are inactive, and automated bots fail to reach human verifiers. Consequently, silently abandoned code is not safer; rather, **its vulnerabilities remain latent and uncatalogued in public databases**.

Finding 3: Maintenance inactivity exhibits a statistically significant relationship ($p = 0.00455$) with vulnerability reporting. Abandoned packages suffer from an observational blindspot where defects are less likely to be formally reported despite lacking security maintenance.

V. DISCUSSION & PRACTICAL IMPLICATIONS

A. Implications for Software Practitioners

1. **Transitive Dependency Auditing:** Development teams commonly monitor top-level dependencies declared in `requirements.txt` or `pyproject.toml`. However, our findings show that silent abandonment thrives in

transitive layers. Teams must integrate software bill of materials (SBOM) tools (e.g., CycloneDX, Syft) into CI/CD pipelines to audit dependencies at depth ≥ 2 .

2. **Beyond CVE Scanning:** Security audits that rely solely on CVE/GHSA lookup tables will fail to detect risks in abandoned packages due to the reporting blindspot identified in RQ3. Teams should adopt *maintainer health metrics* (e.g., OpenSSF Scorecard) to flag libraries exhibiting stagnant release velocity.

B. Implications for Ecosystem Stewards & PyPI

1. **Automated Abandonment Signals:** PyPI currently supports explicit deprecation metadata, but lacks automated badges for prolonged inactivity. PyPI should introduce objective dormancy badges when a package has had no release for > 18 months.
2. **Account Succession Protocols:** PyPI should expand account succession and co-maintainership programs (such as PEP 541 package takeover requests) to enable vetted community members to adopt critical abandoned dependencies safely.

VI. THREATS TO VALIDITY

- **Construct Validity:** We operationalized single-maintainer status using author and organizational attribution heuristics. While some solo accounts represent corporate developers and some teams use a single release account, our manual spot-checks confirmed $> 92\%$ agreement with actual repository commit topologies.
- **Internal Validity:** Vulnerability data was collected from OSV.dev. While OSV aggregates GHSA, PyPA, and NVD, zero-day vulnerabilities or vulnerabilities discussed exclusively in private issue trackers are inherently excluded.
- **External Validity:** Our findings are grounded in PyPI's top 1,000 packages and their dependency trees. While this covers the overwhelming majority of production Python deployments, the conclusions may not directly generalize to niche, non-curated packages or other language ecosystems (e.g., Go, Rust).

VII. CONCLUSION & FUTURE WORK

In this empirical study, we analyzed 1,303 packages across 3,022 dependency edges derived from PyPI's most critical software components. We established that **75.9% of dependencies rely on a single maintainer** and **14.2% are silently abandoned**, with over 66% exhibiting elevated operational risk. Furthermore, we demonstrated a statistically significant association between project health and vulnerability reporting, identifying a systemic blindspot wherein dormant packages mask unreported defects.

Future research will extend this methodology to dynamic runtime tracing to observe whether abandoned code paths are actually executed in common containerized environments, and evaluate automated LLM-based refactoring agents designed to excise abandoned dependencies safely.

DATA & ARTIFACT AVAILABILITY

To enable exact replication, all data collection scripts, resolved dependency graphs, classified datasets, and high-resolution figures have been open-sourced and archived:

- GitHub Repository: <https://github.com/raihan-sifat/pypi-dependency-health-study>

- Zenodo Archive & DOI: <https://doi.org/10.5281/zenodo.XXXXXXX>

REFERENCES

1. G. Avelino, L. Passos, A. Hora, and M. T. Valente, "Assessing the bus factor of Git repositories," in *Proc. IEEE Int. Conf. Softw. Architecture (ICSA)*, 2016, pp. 131–140.
2. A. Decan, T. Mens, and P. Grosjean, "An empirical comparison of dependency network evolution in seven software packaging ecosystems," *Empirical Softw. Eng.*, vol. 24, no. 1, pp. 381–416, 2019.
3. R. G. Kula, D. M. German, A. Ouni, T. Ishio, and K. Inoue, "Do developers update their library dependencies?" *Empirical Softw. Eng.*, vol. 23, no. 1, pp. 384–417, 2018.
4. P. Ladisa, H. Plate, M. Martinez, and J. R. Falleri, "SoK: Taxonomy of attacks on open-source software supply chains," in *Proc. IEEE Symp. Security and Privacy (S&P)*, 2023, pp. 1509–1526.
5. M. Valiev, B. Vasilescu, and J. Herbsleb, "Ecosystem-level determinants of sustained activity in open-source software projects," in *Proc. 26th ACM Joint Eur. Softw. Eng. Conf. and Symp. Found. Softw. Eng. (ESEC/FSE)*, 2018, pp. 644–655.
6. M. Alfadel, D. E. Costa, E. Shihab, and B. Adams, "Empirical analysis of security vulnerabilities in Python packages," *IEEE Trans. Softw. Eng.*, vol. 48, no. 12, pp. 4880–4896, 2021.
7. I. Pashchenko, D.-L. Vu, and F. Massacci, "A qualitative study of dependency management and its security implications," in *Proc. ACM Conf. Comput. Commun. Security (CCS) Workshops*, 2020, pp. 1–12.
8. M. Ohm, H. Plate, M. Sykosch, and M. Meier, "Backstabber's knife collection: A review of open source software supply chain attacks," in *Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA)*, 2020, pp. 23–43.
9. Google Open Source Security Team, "Open Source Vulnerabilities (OSV) Database," 2024. [Online]. Available: <https://osv.dev>
10. H. van Kemenade, "Top PyPI Packages: Monthly Download Statistics," 2024. [Online]. Available: <https://hugovk.github.io/top-pypi-packages>